Pontificia Universidad Católica de Chile
Escuela de Ingeniería
IIC3253 – Criptografía y Seguridad Computacional
Primer Semestre del 2026

Ayudantía 08

Hash-Based Message Authentication Code HMAC

Ayudante: Manuel Villablanca – `manuel.villablanca@uc.cl`

Problema 1

¿Por qué en la construcción de Merkle-Damgård $Pad(m)$ incluye el largo del mensaje? ¿Qué propiedad necesaria se rompería en caso contrario? Dé un ejemplo concreto para ilustrar qué pasa en el caso de que no se incluya el largo del mensaje.

Problema 2

JSON Web Token (JWT) es un estándar que permite transmitir información de forma segura. Un JWT tiene la forma:

Header.Payload.Signature

Estructura

- **Header:** Contiene el tipo de token y el algoritmo de firma utilizado.

```
Header = {"alg": "HS256", "typ": "JWT"}
```

- **Payload:** Contiene los "claims" o afirmaciones sobre una entidad y datos adicionales.

```
Payload = {
    "sub": "1234567890",
    "name": "Usuario Ejemplo",
    "admin": true
}
```

- **Signature:** Se calcula utilizando HMAC sobre el header y payload codificados en base64.

La firma se calcula de la siguiente manera:

```
Signature = HMAC-SHA256(base64UrlEncode(Header) + '.'
+ base64UrlEncode(Payload), secret)
```

Un ejemplo de JWT completo sería:


```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.
eyJzdWIiOiIxMjM0NTY3ODkwIiwibmFtZSI6IlVzdWFyaW8gRWplbXBsbyIsImFkbWluIjp0cnVlfQ.
rDZ6zA5T823vxlFBwXXDhxPE-GSYxNYnMl5jP1PL1JQ
```


El receptor del token puede verificar su autenticidad recalculando la firma con la clave secreta compartida.

Afirmaciones

En base a lo anterior, responde si las siguientes afirmaciones son verdaderas o falsas, justificando tu decisión:

1. Si la clave secreta utilizada en HMAC para JWT es revelada, la seguridad del sistema permanece intacta.
2. Un atacante que intercepta un JWT válido puede modificar el payload para cambiar la identidad del usuario o sus privilegios sin invalidar la firma.
3. HMAC proporciona las mismas garantías de seguridad que un simple hash del mensaje cuando se usa en JWT.
4. Utilizar $MACk(M) = h(k||M)$ en lugar de HMAC para generar la firma del JWT es seguro contra ataques de extensión.

Problema 3

1. Demuestre que definir $MAC_k(M) = h(k\|M)$ resulta en un MAC inseguro. Es decir, demuestre que dado un par texto/MAC válido (M, H), se puede construir eficientemente otro par texto/MAC válido (M', H') sin conocer la clave k. Asuma por simplicidad que la longitud de la clave es igual a la longitud del bloque del mensaje $|k| = |M_i|$.

   Pista: La función de compresión h' es, por supuesto, conocida, es decir, dadas las dos entradas cualquiera puede calcular su salida.

2. Demuestre que añadir la clave secreta k al final, es decir, definir $MAC_k(M) = h(M\|k)$ resulta en un MAC inseguro. Recuerde que, por definición, la propiedad de ser resistente a colisiones para un MAC significa que encontrar dos mensajes $x \neq x'$ tales que:

$$MAC(x, k) = MAC(x', k),$$

implica el esfuerzo computacional de 2^n operaciones, donde n es el tamaño del MAC (y del hash). Describa un ataque (basado en la estructura Merkle-Damgård anterior) que utilice menos de 2^n operaciones para crear una falsificación MAC, un valor MAC legítimo para algún mensaje x' sin revelar la clave k.

3. Seria seguro definir $MAC_k(M) = h(k||h(M))$? Argumente.